

CVEFixes experiments: Rerun agents

Checkpoint 10

Lívia Cavalcanti

July 2026

Evaluation Metrics

Hit@1

Success rate at rank 1

$$\frac{1}{|Q|} \sum_q \mathbb{1}[\text{rank}_q = 1]$$

Fraction of queries where the correct match is ranked **first**.

Hit@5

Success rate in top 5

$$\frac{1}{|Q|} \sum_q \mathbb{1}[\text{rank}_q \leq 5]$$

Fraction of queries where the correct match appears in **top 5**.

MRR

Mean Reciprocal Rank

$$\frac{1}{|Q|} \sum_q \frac{1}{\text{rank}_q}$$

Average inverse rank across queries — rewards **higher** placements.

BERTScore

Patch quality via embeddings

$$\frac{2 \cdot P \cdot R}{P + R}$$

Harmonic mean of contextual embedding-based precision & recall.

AutoPatch Dataset Results (n=225)

Embedder	H@1	H@5	MRR	CWE R.
<i>Structure-Only</i>				
Combined	0.8904	0.9589	0.9162	0.4978
GIN	0.7260	0.8767	0.7879	0.4427
WL	0.6986	0.7945	0.7363	0.4386
<i>CodeBERT pretrained</i>				
CodeBERT (baseline)	0.1533	0.2200	0.1826	0.2933
CodeBERT (seq)	0.7534	0.8630	0.7927	0.4121
CodeBERT (pat)	0.7123	0.8356	0.7677	0.4147

Source: `experiments/output/checkpoint5/20260505_141347_experiment_f59ab1/results.json`

RQ1: validated — structural *graph* representations are *effective* for vulnerability pattern retrieval in a synthetic dataset.

AutoPatch Dataset: CWE Distribution

Distribution of CWE Types in the AutoPatch Dataset ($N = 75$ real-world CVEs)

CWE ID	Category Group	CWE Description	Count	Ratio (%)
CWE-20	Validation & Logic	Improper Input Validation	20	26.67%
CWE-362	Concurrency	Race Condition / Synchronization	16	21.33%
CWE-252	Validation & Logic	Unchecked Return Value	12	16.00%
CWE-843	Type Errors	Type Confusion	8	10.67%
CWE-416	Memory Safety	Use After Free	6	8.00%
CWE-476	Memory Safety	NULL Pointer Dereference	4	5.33%
CWE-703	Validation & Logic	Improper Handling of Exceptional Conditions	3	4.00%
CWE-122	Memory Safety	Heap-based Buffer Overflow	1	1.33%
CWE-125	Memory Safety	Out-of-bounds Read	1	1.33%
CWE-787	Memory Safety	Out-of-bounds Write	1	1.33%
CWE-400	Resource Handling	Uncontrolled Resource Consumption	1	1.33%
CWE-754	Validation & Logic	Improper Check for Unusual Conditions	1	1.33%
CWE-775	Resource Handling	Missing Release of Resource	1	1.33%
Total			75	100.00%

The dataset is heavily weighted toward **Validation & Logic** errors (49.3%) and **Concurrency / Race Conditions** (21.3%). The top three CWE types (**CWE-20**, **CWE-362**, and **CWE-252**) account for over **64%** of all evaluated vulnerability instances.

Question: Does the approach generalize to real-world vulnerabilities?

Real-World Dataset

CVEFixes datasets is large dataset with real-world CVEs collected from the U.S. National Vulnerability Database, patches, and code changes.

Metric	Value
CVEs	11,873
Fix commits	12,107
File changes	51,342
Method changes	277,948
Repositories	4,249

Sampling criteria

Structurally distinguishable CWEs (e.g. UAF vs. OOB) to test pattern matching, not just code similarity
Balanced superclass(CWE) up to 20 entries and subclasses (CVE) to ensure retrieval feasibility

Parameter	Value
Total pairs	136
Index set	109
Query set	27
Unique CVEs (index)	60
Unique CVEs (query)	25
CWE classes	7

[NEW] CVEfixes Dataset

Question: Does the approach generalize to real-world vulnerabilities?

Real-World Dataset

CVEFixes datasets is large dataset with real-world CVEs collected from the U.S. National Vulnerability Database, patches, and code changes.

Metric	Value
CVEs	11,873
Fix commits	12,107
File changes	51,342
Method changes	277,948
Repositories	4,249

Sampling criteria

Structurally distinguishable CWEs (e.g. UAF vs. OOB) to test pattern matching, not just code similarity
Balanced superclass(CWE) and at least 5 entries for each subclasse (CVE) to ensure retrieval feasibility

Parameter	Value
Total pairs	450
Index set	360
Test set	90
Unique CVEs (index)	26
Unique CVEs (query)	25
CWE classes	6

[OLD] Function vs. File: Same-Split Comparison

Function-level vs File-level Input (identical paired sample & split: n=122 index, 37 query; seed 42; G_{vuln})

Embedder	Input	Hit@1	Hit@5	Hit@10	MRR	CWE R.
GIN	function	0.108	0.243	0.270	0.152	0.205
GIN	file	0.081	0.189	0.216	0.122	0.145
Combined	function	0.054	0.432	0.486	0.190	0.192
Combined	file	0.622	0.649	0.730	0.642	0.255
CodeBERT (seq)	function	0.351	0.595	0.730	0.451	0.249
CodeBERT (seq)	file	0.811	0.865	0.919	0.845	0.281
CodeBERT (pat)	function	0.351	0.649	0.784	0.463	0.264
CodeBERT (pat)	file	0.757	0.811	0.865	0.785	0.289

On an **identical sample and split** (both levels share the same 122 index / 37 query instances), file-level input strongly improves the semantic and fusion embedders — Combined Hit@1 **+0.57**, CodeBERT (seq) Hit@1 **+0.46** / MRR **+0.39**, CodeBERT (pat) Hit@1 **+0.41**. The exception is **GIN** (pure topology, **-0.03** Hit@1): the wider file context adds structure the semantic embedders exploit but that slightly dilutes GIN's topology-only signal.

[NEW] Function vs. File: Same-Split Comparison

Function-level vs File-level Input (identical paired sample & split: n=122 index, 37 query; seed 42; G_{vuln})

Embedder	Input	Hit@1	Hit@5	Hit@10	MRR	CWE R.
Combined	function	0.333	0.656	0.811	0.454	0.384
Combined	file	0.889	1.000	1.000	0.944	0.750
CodeBERT (seq)	function	0.722	0.778	0.789	0.741	0.627
CodeBERT (seq)	file	0.889	0.889	0.889	0.889	0.605
CodeBERT (pat)	function	0.678	0.789	0.789	0.720	0.619
CodeBERT (pat)	file	0.889	0.889	0.889	0.889	0.650

On an **identical sample and split**, shifting from function-level to file-level input consistently boosts performance across all models — Combined Hit@1 **+0.556** / MRR **+0.490**, CodeBERT (seq) Hit@1 **+0.167**, CodeBERT (pat) Hit@1 **+0.211**. The only minor regression occurs in CodeBERT (seq) CWE Recall (**-0.022**), while file context pushes Combined to perfect top-5/10 retrieval.

[NEW] Patch Evaluation Across CWEs

Patch Evaluation Metrics Across CWEs (GPT-5.3-Codex, CodeBERT Sequence Embedder; $N = 88$)

Category	Count	Exact Match	Hunk F1	BERTScore F1	BLEU-4	ROUGE-L
CWE-190	15	5	0.6149	0.6960	0.7504	0.7908
CWE-20	15	3	0.8643	0.9121	0.8579	0.9293
CWE-362	15	8	0.9983	0.9648	0.9912	0.9961
CWE-416	14	10	0.9344	0.9387	0.9593	0.9730
CWE-476	14	9	0.9007	0.9334	0.8910	0.9246
CWE-787	15	0	0.2625	0.5243	0.8941	0.9431
General (All)	88	35	0.7590	0.8258	0.8899	0.9256

Performance varies by vulnerability type: **CWE-362** (Race Conditions) achieves near-perfect fidelity (Hunk F1 **0.9983**, ROUGE-L **0.9961**), whereas **CWE-787** (Out-of-bounds Write) proves most challenging with 0 exact matches and a Hunk F1 of only **0.2625**.

Source: `cwe_evaluation_gpt5.3_codebert_seq.json`

[NEW] Patch Evaluation Across CWEs (CodeBERT_seq and GPT-4o)

Patch Evaluation Metrics Across CWEs ($N = 20$, Evaluated=14, Skipped=6)

Category	Total	Evaluated	Skipped	Exact Match	Hunk F1	BERTScore F1	BLEU-4	ROUGE-L
CWE-362	11	11	0	4	0.9553	0.4771	0.4528	0.4889
CWE-476	3	3	0	1	0.3333	0.6983	0.7506	0.7931
Skipped/Unchecked	6	0	6	—	—	—	—	—
General (All)	20	14	6	5	0.8220	0.5245	0.5166	0.5541

Evaluation Scope & Skipping: Out of 20 total records, **6 entries (30%) were skipped** prior to evaluation. Across the 14 evaluated records, **CWE-362** leads in Hunk F1 (**0.9553**) and exact matches (4/11), whereas **CWE-476** achieves higher standard semantic similarity scores (BLEU-4 **0.7506**, ROUGE-L **0.7931**).

Questions?

Livia Cavalcanti |  graph-rag/